VulnScan Pro

Security Assessment Report

Target URL: http://demo.testfire.net

Scan Date: 2026-04-23 19:00:40

Overall Score: 0/100 (Grade: F)

Executive Summary

Security score is 0/100. Found 2 critical vulnerabilities requiring immediate attention.

OWASP Mapping

OWASP Category	CWE	CVSS	Finding	Severity
A01:2021 - Broken Access Control				
	CWE-352	6.1	Cookie (SameSite)	LOW
A02:2021 - Cryptographic Failures				
	CWE-298	7.4	Invalid Cert	HIGH
	CWE-614	5.3	CSRF vulnerability at http://demo.testfire.net/doLogin	HIGH
	CWE-614	5.3	CSRF vulnerability at http://demo.testfire.net/sendFeedback	HIGH
	CWE-614	5.3	CSRF vulnerability at http://demo.testfire.net/doSubscribe	HIGH
	CWE-614	5.3	CSRF vulnerability at http://demo.testfire.net/admin/doLogin	HIGH
A03:2021 - Injection				
	CWE-79	6.1	X-XSS-Protection	MEDIUM
A05:2021 - Security Misconfiguration				
	CWE-319	7.4	Strict-Transport-Security	HIGH
	CWE-923	7.3	Port 80 open	INFO
	CWE-923	7.3	Port 443 open	INFO
	CWE-923	7.3	Port 8080 open	INFO
	CWE-693	6.1	Content-Security-Policy	HIGH
	CWE-1021	6.1	X-Frame-Options	MEDIUM
	CWE-183	5.3	Missing SPF	MEDIUM
	CWE-693	4.3	X-Content-Type-Options	MEDIUM
A06:2021 - Vulnerable and Outdated Components				
	CWE-1104	7.5	No WAF Detected	MEDIUM
	CWE-1104	7.5	Referrer-Policy	LOW
	CWE-1104	7.5	Permissions-Policy	LOW
	CWE-1104	7.5	Cache-Control	INFO
	CWE-1104	7.5	Cookie (JSESSIONID)	MEDIUM
	CWE-1104	7.5	Vuln at http://demo.testfire.net/search.jsp	HIGH
	CWE-1104	7.5	Vuln at http://demo.testfire.net/sendFeedback	HIGH
	CWE-1104	7.5	Vuln at http://demo.testfire.net/doLogin	HIGH
	CWE-1104	7.5	Vuln at http://demo.testfire.net/doLogin	HIGH
	CWE-1104	7.5	Hardcoded secret or password found	HIGH
	CWE-1104	7.5	Localhost reference found (dev config?)	LOW

OWASP Category	CWE	CVSS	Finding	Severity
	CWE-1104	7.5	Localhost reference found (dev config?)	LOW

Waf

Finding	Severity	Description	Recommendation
No WAF Detected	MEDIUM	No Web Application Firewall was detected in front of this application.	Consider deploying a WAF (e.g. Cloudflare

Port Scan

Finding	Severity	Description	Recommendation
Port 80 open	INFO	Service: HTTP	
Port 443 open	INFO	Service: HTTPS	
Port 8080 open	INFO	Service: HTTP-Proxy	

Headers

Finding	Severity	Description	Recommendation
Content-Security-Policy	HIGH	Missing	Implement CSP to prevent XSS.
Strict-Transport-Security	HIGH	Missing	Enforce HTTPS connections using HSTS.
X-Frame-Options	MEDIUM	Missing	Prevent clickjacking by setting to DENY or
X-Content-Type-Options	MEDIUM	Missing	Set to nosniff to prevent MIME confusion a
X-XSS-Protection	MEDIUM	Missing	Enable browser built-in XSS protection (tho
Referrer-Policy	LOW	Missing	Control referrer information sent to other si
Permissions-Policy	LOW	Missing	Restrict access to browser features like ca
Cache-Control	INFO	Missing	Ensure sensitive pages are not cached.
Cookie (JSESSIONID)	MEDIUM	Missing	Add Secure flag to cookie JSESSIONID.
Cookie (SameSite)	LOW	Missing	Add SameSite attribute to cookies to prote

Ssl

Finding	Severity	Description	Recommendation
Invalid Cert	HIGH	Cert is expired or invalid	Renew cert

Dns

Finding	Severity	Description	Recommendation
Missing SPF	MEDIUM	No SPF record found	Add SPF record

Xss

Finding	Severity	Description	Recommendation
Vuln at http://demo.testfire.net/search.jsp	HIGH	Param query vulnerable to payload <script>alert(1)</script>	Sanitize inputs and use prepared statemen
Vuln at http://demo.testfire.net/sendFeedback	HIGH	Param name vulnerable to payload <script>alert(1)</script>	Sanitize inputs and use prepared statemen

Sqli

Finding	Severity	Description	Recommendation
Vuln at http://demo.testfire.net/doLogin	HIGH	Param uid vulnerable to payload '; SELECT 1/0--	Sanitize inputs and use prepared statemen
Vuln at http://demo.testfire.net/doLogin	HIGH	Param passw vulnerable to payload '; SELECT 1/0--	Sanitize inputs and use prepared statemen

Js Analysis

Finding	Severity	Description	Recommendation
Hardcoded secret or password found	HIGH	Found in JS file: http://demo.testfire.net/swagger/swagger-ui-bundle.js Evidence: A	Move secrets to server-side env vars
Localhost reference found (dev config?)	LOW	Found in JS file: http://demo.testfire.net/swagger/swagger-ui-bundle.js Evidence: s	Remove debug/dev configuration before
Localhost reference found (dev config?)	LOW	Found in JS file: http://demo.testfire.net/swagger/swagger-ui-standalone-preset.js Evidence: s	Remove debug/dev configuration before

Csrf

Finding	Severity	Description	Recommendation
CSRF vulnerability at http://demo.testfire.net/doLogin	HIGH	POST form has no CSRF token and no custom header	Implement Synchronized Token Pattern
CSRF vulnerability at http://demo.testfire.net/sendFeedback	HIGH	POST form has no CSRF token and no custom header	Implement Synchronized Token Pattern
CSRF vulnerability at http://demo.testfire.net/subscribe.jsp	HIGH	POST form has no CSRF token and no custom header	Implement Synchronized Token Pattern
CSRF vulnerability at http://demo.testfire.net/admin/admin.jsp	HIGH	POST form has no CSRF token and no custom header	Implement Synchronized Token Pattern

Remediation Checklist

Follow these recommendations to improve your security posture:

• Implement CSP to prevent XSS.

• Enforce HTTPS connections using HSTS.

• Renew cert

• Sanitize inputs and use prepared statements.

• Move secrets to server-side environment variables. Never include credentials in JavaScript.

• Implement the Synchronizer Token Pattern: generate a cryptographically random per-session token, embed it as a hidden field in every state-changing form, and validate it server-side. Also set SameSite=Lax or Strict on session cookies as a defence-in-depth measure.